

01 Broken Function Level Authorization

Broken Function Level Authorization occurs when an API verifies who a user is but does not check what they are allowed to do.

Attackers can exploit this by using normal accounts to invoke privileged functions, such as admin endpoints.

Prevent this by denying access by default and ensuring centralized, server-side checks of the user's role for each endpoint.